

CL

CONFIDENTIAL
SECURITY REPORT

Vulnerability Assessment and Penetration Testing Report

WEB APPLICATION VAPT

Prepared for

Crestline Learning Technologies Pvt. Ltd.
AsterLearn Campus LMS

Engagement ID	NQ-CLT-WA-2606
Assessment Window	29 May 2026 - 03 June 2026
Report Date	05 June 2026
Environment	UAT / Staging
Prepared by	NorthQuill Cyber Assurance LLP

Assessment scope

Student, Instructor and administrator workflows for course enrolment, grade management, assignment submission, announcements, analytics and document downloads.

Document classification: Confidential - authorized stakeholders only

01

Document Control and Engagement Snapshot

Report metadata, classification and distribution

This report presents the validated security observations, business impact and remediation guidance from the AsterLearn Campus LMS VAPT engagement.

HIGH

Overall risk

8

Findings

3

High

5

Medium

Engagement metadata	
Client organization	Crestline Learning Technologies Pvt. Ltd.
Application assessed	AsterLearn Campus LMS
Business domain	Education technology, campus learning management, gradebook, assignment submission and student analytics
Assessment type	Authenticated web application VAPT with supporting API validation
Assessment window	29 May 2026 to 03 June 2026
Report date / version	05 June 2026 / v1.0
Prepared by	NorthQuill Cyber Assurance LLP
Distribution	CISO, CTO, Product Owner, LMS Engineering Lead, DevOps Lead, QA Manager

Name / Role	Responsibility	Status
Meera Iyer / Security Sponsor	Review risk position and remediation ownership	For review
Rohan Dutt / Product Owner	Coordinate engineering remediation and user-pilot readiness	For action
Kavya Menon / Lead Assessor	Validation, reporting and retest planning	Submitted

Contents and Reporting Conventions

Static page index and evidence handling conventions

Section	Page
1. Document Control and Engagement Snapshot	2
2. Contents and Reporting Conventions	3
3. Audit Engagement Summary	4
4. Engagement Scope, Credentials and Sampling	5
5. Audit Methodology, Criteria and Approach	6
6. Audit Activities, Timelines, Team and Tools	7
7. Executive Summary	8
8. Detailed Observation Register	9
9. Detailed Observations CLT-AL-01 to CLT-AL-08	10-17
10. Remediation Roadmap and Closure Notes	18

Reporting conventions

Severity model	Severity is based on exploitability, exposure, business impact, data sensitivity, affected role and release-readiness context.
Evidence handling	Screenshots and HTTP excerpts are masked where needed. Tokens, IDs and personal details are modified or partially redacted while preserving technical validity.
Status values	Open indicates reproducible at report issuance. Closure requires retesting against a patched build or documented risk acceptance.
Environment note	Testing was conducted against UAT/staging assets provided by Crestline Learning Technologies and did not include production exploitation.

03		Audit Engagement Summary Introduction, objective, limitations and assumptions	
Introduction NorthQuill Cyber Assurance LLP performed a time-bound VAPT of the AsterLearn Campus LMS used by institutions for course delivery, student enrolment, assessments, grade management, assignment submissions and analytics dashboards.		Objective The objective was to identify exploitable weaknesses before the next user-pilot release, validate access-control boundaries across student, teaching assistant, instructor and administrator roles, and provide actionable remediation guidance.	
Limitations The engagement was limited to the approved UAT environment, supplied roles and reachable workflows. No production systems, destructive testing, social engineering, denial-of-service testing or third-party SaaS penetration was performed.		Assumptions Provided credentials represented intended role permissions. UAT configuration was assumed to be materially aligned to the planned release except where explicitly noted by the client.	

Engagement conclusion

The LMS demonstrated a functional security baseline for authentication and transport security, but material weaknesses were identified in authorization enforcement, role assignment, stored content handling and several browser/API configuration controls. The three high-risk findings should be addressed before production release or broad user pilot.

Management risk statement	High overall risk due to confirmed cross-institution data exposure, role escalation and stored XSS impacting student/instructor trust boundaries.
Recommended release posture	Proceed only after P1 remediation has been verified and compensating monitoring is enabled for remaining P2/P3 items.
Primary affected control families	Access control, identity recovery, input/output handling, data export handling and security configuration.

04

Engagement Scope, Credentials and Sampling

Approved target coverage and test identities

Engagement scope

In-scope application	AsterLearn Campus LMS web application and supporting UAT APIs exposed at <code>uat.asterlearn.example</code>
Core workflows tested	Login, password reset, student profile, enrolment, course group membership, announcements, gradebook, assignment upload/download, analytics dashboard and CSV exports.
Roles exercised	Student, teaching assistant, instructor, institution administrator and platform support viewer.
Test data boundary	Synthetic UAT institution and user records supplied by the client. Evidence masks or alters personal identifiers.
Network location	Remote authenticated testing from assessor-controlled IP addresses allow-listed by the client.

Testing credentials

Role	Credential label	Purpose	Access level
Student	<code>student.greenfield.qa</code>	Learner workflows, own profile, course materials and assignment submissions	Low
Teaching assistant	<code>ta.dbms.qa</code>	Course group support, grade comments and learner additions	Medium
Instructor	<code>instructor.cse.qa</code>	Announcements, gradebook, course modules and class analytics	High
Institution admin	<code>admin.greenfield.qa</code>	Institution user administration, exports and reporting	High
Support viewer	<code>support.readonly.qa</code>	Read-only support and operational diagnostics	Medium

Exclusions / additions / deviations and sampling criteria

Exclusions	Production systems, payment integrations, third-party video conferencing provider, destructive load testing, phishing/social engineering and physical security testing.
Additions	API-level verification was performed for selected workflows discovered through browser traffic, including authorization and export-related endpoints.
Deviations	No material deviation from agreed scope. OTP testing was rate-limited by the assessor to avoid operational disturbance.
Sampling criteria	Tests prioritized workflows handling student personal data, grades, submissions, role assignment, institution separation and administrator exports.

Methodology overview

Phase	Activity	Output
1. Planning	Confirmed scope, test windows, roles, URLs, credential handling and communication channels.	Approved test plan and engagement guardrails.
2. Discovery	Mapped application routes, APIs, role boundaries, tokens, session behavior and trust assumptions.	Target workflow inventory and attack surface map.
3. Validation	Performed manual and tool-assisted testing for access control, injection, auth recovery, file handling and browser controls.	Confirmed findings with reproducible evidence.
4. Risk analysis	Rated observations using exploitability, likelihood, business impact and affected data sensitivity.	Prioritized risk register.
5. Reporting	Documented evidence, root cause hypotheses, remediation recommendations and retest criteria.	Final VAPT report and remediation roadmap.

Criteria / standards referred for audit

OWASP Web Security Testing Guide	Used for web application testing coverage including authentication, session, input validation, authorization and configuration testing.
OWASP Application Security Verification Standard	Used for control expectations around access control, authentication, validation, error handling and data protection.
OWASP Top 10 and OWASP API Security Top 10	Used for executive mapping and common risk taxonomy for web/API vulnerabilities.
CVSS v3.1	Used as a reference score for severity calibration, with business context applied for final prioritization.

Type of assessment and testing environment

Assessment type	Grey-box authenticated VAPT with manual exploitation validation and selected API request manipulation.
Testing environment	UAT / staging application environment with synthetic learner, instructor and administrator data.
Safety controls	No destructive payloads, no persistence attempts beyond harmless audit markers, no high-volume automation and no production data access.

06

Audit Activities, Timelines, Team and Tools

Execution calendar, team details and tooling

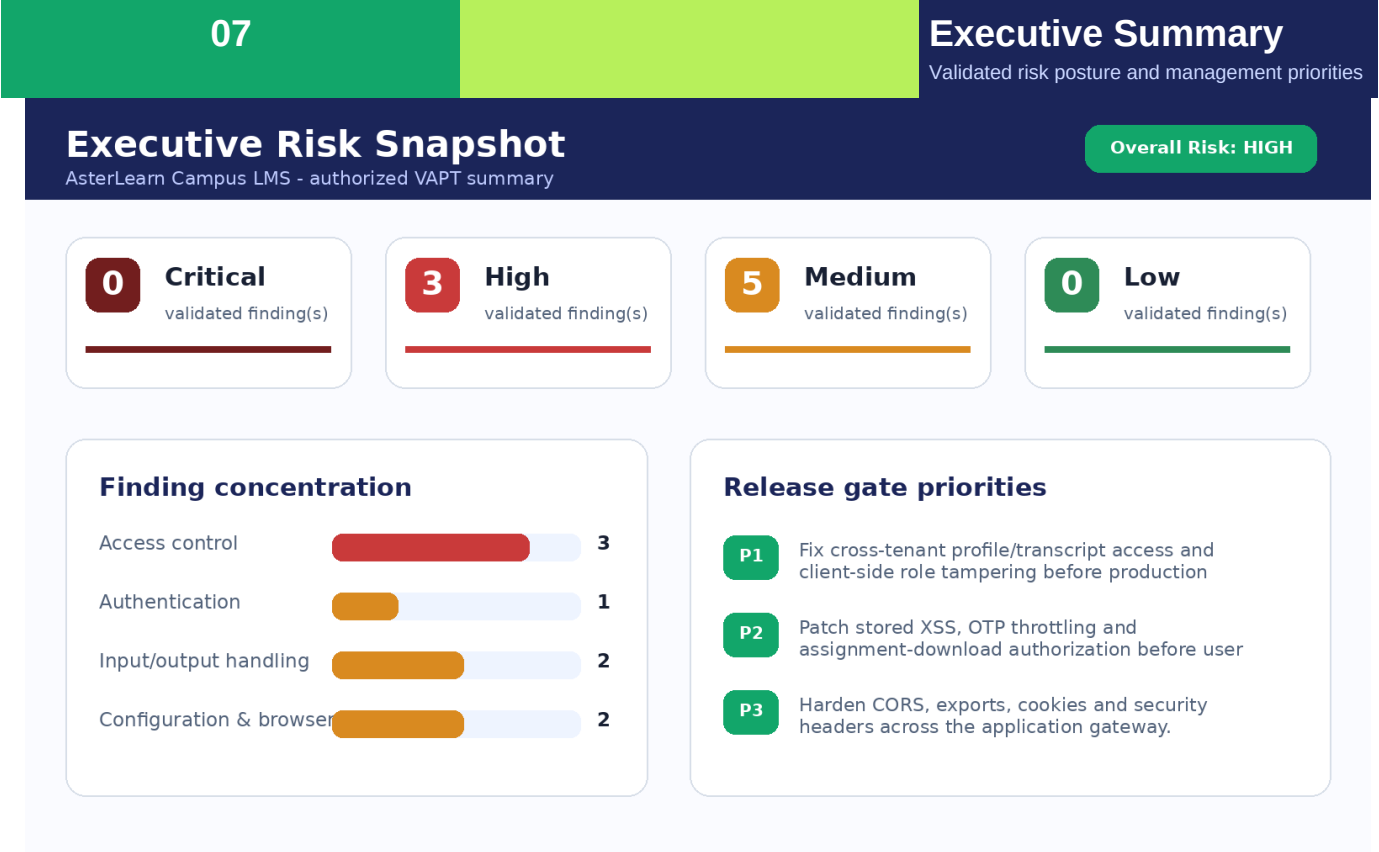
Date	Audit activity	Output
29 May 2026	Kick-off, scope confirmation, credential validation and target reachability checks.	Ready-to-test confirmation
30 May 2026	Application mapping, role baseline capture and authenticated workflow enumeration.	Workflow map and role matrix
31 May 2026	Manual access-control testing for profiles, submissions, gradebook and course groups.	Authorization findings validated
01 June 2026	Input handling, stored content, file download, export and browser security tests.	XSS/export/configuration evidence
02 June 2026	Identity recovery checks, CORS validation, evidence normalization and peer review.	Validated final finding set
03 June 2026	Risk rating, remediation mapping and management summary preparation.	Report package

Details of auditing team

Name	Role	Responsibility
Kavya Menon	Lead Security Assessor	Testing strategy, high-risk validation, final risk calibration
Aditya Narang	Application Security Consultant	API testing, access control and input validation
Sana Qureshi	Security Analyst	Evidence capture, tool-assisted scanning and documentation
Nikhil Rao	QA Reviewer	Finding reproducibility checks and report quality review

Tools / software used

Intercepting proxy and API tooling	Burp Suite Professional, Postman, browser developer tools
Reconnaissance and validation	Nmap for allowed host checks, curl/httpie for header validation, custom scripts for controlled request replay
Browser and client testing	Chrome, Firefox, spreadsheet client checks for CSV behavior
Documentation and evidence handling	Encrypted assessor workspace, sanitized screenshot capture and manual peer review



08		Detailed Observation Register			
		Prioritized list of validated findings			
ID	Severity	CVSS	Observation	Affected component	Priority
CLT-AL-01	High	8.2	Broken object-level authorization exposes student profiles across institutions	GET /api/v2/students/{studentId}/profile	P1
CLT-AL-02		7.8	Client-controlled role parameter permits instructor privilege escalation	POST /api/v2/course-groups/{groupId}/members	P1
CLT-AL-03		7.6	Stored cross-site scripting in course announcements	POST /api/v2/courses/{courseId}/announcements and student dashboard announcement widget	P1
CLT-AL-04	Medium	6.8	Password reset OTP endpoint lacks effective throttling and lockout	POST /api/v2/auth/password-reset/verify	P2
CLT-AL-05		6.5	Assignment submission files are downloadable through predictable file keys	GET /api/v2/submissions/files/{fileKey}/download	P2
CLT-AL-06		6.2	Credentialed CORS policy reflects untrusted origins	/api/v2/analytics/* and /api/v2/students/*	P2
CLT-AL-07		5.9	Grade export is vulnerable to spreadsheet formula injection	POST /api/v2/gradebook/comments and GET /api/v2/gradebook/export.csv	P3
CLT-AL-08		5.4	Missing security headers and weak SameSite cookie setting reduce browser-side protections	Primary web responses including /login, /dashboard, /courses and /gradebook	P3

Severity rating criteria

High

Confirmed weakness with material data exposure, privilege escalation, stored execution path or release-blocking impact.

Medium

Confirmed weakness with realistic abuse path but constrained by role, workflow, user interaction, data scope or other preconditions.

Low / Informational

Defense-in-depth or hygiene item with limited direct exploitability in the assessed context.

Detailed observations use an evidence-led format: each finding includes a masked HTTP proof, reproducibility notes, impact, likely root cause and recommended remediation.

01		CLT-AL-01 - Broken object-level authorization exposes student profiles across institutions		
		Severity: High CVSS: 8.2 Owner: Backend Engineering		
Severity	CVSS v3.1	Priority	Status	OWASP mapping
High	8.2	P1	Open	OWASP Top 10: A01 Broken Access Control / OWASP API1:2023 BOLA

NorthQuill Evidence Console - Repeater - CLT-AL-01

ProxyRepeaterComparerLoggerNotes

Broken object-level authorization exposes student profiles across institutions

Evidence captured in authorized UAT scope. Session tokens, user identifiers and personal data are masked.

REQUEST

```
GET /api/v2/students/STU-WCA-77182/profile HTTP/2
Host: uat.asterlearn.example
Authorization: Bearer eyJhbGciOi...student.greenfield
X-Institution-ID: greenfield-institute
Accept: application/json

Original permitted object: STU-GFI-10431
Changed object: STU-WCA-77182
```

RESPONSE

```
HTTP/2 200 OK
Content-Type: application/json
Cache-Control: no-store

{
  "studentId": "STU-WCA-77182",
  "institution": "Westbridge College of Arts",
  "fullName": "N. Arora",
  "guardianPhone": "+91-98XX-XX2318",
  "program": "BBA Semester 4",
  "academicStanding": "on_track"
}
```

Validation result:

The Greenfield student token retrieved a Westbridge College profile, confirming cross-institution authorization failure.

Evidence CLT-AL-01: masked request/response proof and validation result

Affected component GET /api/v2/students/{studentId}/profile	Preconditions Authenticated student from Greenfield Institute with access only to their own profile and enrolled courses.
Detailed proof-of-concept steps - Logged in as student.greenfield.qa and captured the profile API request for the permitted student record STU-GFI-10431. - Changed only the studentId path value to STU-WCA-77182, a record from another institution, while keeping the Greenfield session token. - Submitted the modified request and received HTTP 200 with institution, guardian contact and academic summary for the unrelated student.	Business impact Any authenticated student could retrieve personal and academic data for students in other institutions if identifiers are guessed, leaked or enumerated. This creates privacy, contractual and regulatory exposure for the platform.
Likely root cause The API validates authentication but does not enforce institution ownership and subject-level authorization before returning the student profile object.	Recommended remediation Resolve the institution and student context from the authenticated principal on the server, enforce object ownership checks on every read/update path, return 403 for cross-institution access, and add negative authorization tests for all student objects.

Page 10

02		CLT-AL-02 - Client-controlled role parameter permits instructor privilege escalation		
Severity		CVSS v3.1	Priority	Status
High		7.8	P1	Open
		OWASP mapping		
		OWASP Top 10: A01 Broken Access Control / OWASP ASVS V4 Access Control		

NorthQuill Evidence Console - Repeater - CLT-AL-02

ProxyRepeaterComparerLoggerNotes

Client-controlled role parameter permits instructor privilege escalation

Evidence captured in authorized UAT scope. Session tokens, user identifiers and personal data are masked.

REQUEST

POST /api/v2/course-groups/GRP-PHY-2606/members HTTP/2
Host: uat.asterlearn.example
Authorization: Bearer eyJ...teaching_assistant
Content-Type: application/json

{
 "userId": "USR-QA-8842",
 "role": "instructor",
 "notifyUser": false
}

RESPONSE

HTTP/2 201 Created
Content-Type: application/json

{
 "membershipId": "MEM-948522",
 "groupId": "GRP-PHY-2606",
 "userId": "USR-QA-8842",
 "assignedRole": "instructor",
 "permissions": ["grade.update", "announcement.create", "module.publish"]
}

Validation result:

Changing the role field in transit resulted in instructor privileges being assigned by the API.

Evidence CLT-AL-02: masked request/response proof and validation result

Affected component POST /api/v2/course-groups/{groupId}/members	Preconditions Authenticated teaching assistant with permission to add learners to a course group but not assign instructor roles.
Detailed proof-of-concept steps - Captured the group-member creation request from a teaching assistant account while adding a learner to the QA course group. - Modified the role value from learner to instructor before submission. - The API accepted the request and the newly added user appeared as instructor with grade-editing and announcement permissions.	Business impact A lower-privileged teaching assistant can grant elevated course roles and indirectly modify grades, announcements, course materials and attendance records.
Likely root cause The server trusts a client-supplied role parameter instead of deriving permissible roles from the caller permissions and workflow context.	Recommended remediation Perform server-side authorization on role assignment, maintain an allow-list of assignable roles per caller role, require privileged admin workflow for instructor assignment, and log all role changes with approval metadata.

03		CLT-AL-03 - Stored cross-site scripting in course announcements		
Severity		CVSS v3.1	Priority	Status
High		7.6	P1	Open
		OWASP mapping		
		OWASP Top 10: A03 Injection / OWASP ASVS V5 Output Encoding		

NorthQuill Evidence Console - Repeater - CLT-AL-03

ProxyRepeaterComparerLoggerNotes

Stored cross-site scripting in course announcements

Evidence captured in authorized UAT scope. Session tokens, user identifiers and personal data are masked.

REQUEST

POST /api/v2/courses/CSE-SEM4-DBMS/announcements HTTP/2
Host: uat.asterlearn.example
Authorization: Bearer eyJ...course.instructor
Content-Type: application/json

{
 "title": "Lab schedule update",
 "body": "Please read <img src=x
onerror=confirm('AL-260603')>",
 "audience": "enrolled_students"
}

RESPONSE

HTTP/2 201 Created
Content-Type: application/json

{
 "announcementId": "ANN-260603-1882",
 "renderedPreview": "Please read <img src=x
onerror=confirm(...)>",
 "visibleTo": "42 enrolled students",
 "status": "published"
}

Validation result:

Stored content submitted by the instructor was rendered as active HTML in the student dashboard.

Evidence CLT-AL-03: masked request/response proof and validation result

Affected component POST /api/v2/courses/{courseId}/announcements and student dashboard announcement widget	Preconditions Instructor-level user can create announcements for an assigned course.
Detailed proof-of-concept steps - Created an announcement containing a harmless audit marker embedded inside an image error handler. - Opened the course dashboard as an enrolled student in a separate browser profile. - The announcement body rendered as active HTML and triggered the audit marker in the student session.	Business impact An attacker with instructor or compromised instructor access can execute script in student sessions, potentially stealing data displayed in the application, performing actions as the student, or altering course content.
Likely root cause Announcement body content is stored and later inserted into the DOM without strict sanitization or contextual output encoding.	Recommended remediation Encode user-generated content by output context, restrict rich text to a safe allow-list sanitizer, disable dangerous attributes, add a strict Content Security Policy, and include stored XSS regression tests for announcement widgets.

04		CLT-AL-04 - Password reset OTP endpoint lacks effective throttling and logout		
Severity		CVSS v3.1	Priority	Status
Medium		6.8	P2	Open
		OWASP mapping		
		OWASP Top 10: A07 Identification and Authentication Failures / OWASP API2 Broken Authentication		

NorthQuill Evidence Console - Repeater - CLT-AL-04

ProxyRepeaterComparerLoggerNotes

Password reset OTP endpoint lacks effective throttling and logout

Evidence captured in authorized UAT scope. Session tokens, user identifiers and personal data are masked.

REQUEST

POST /api/v2/auth/password-reset/verify HTTP/2
Host: uat.asterlearn.example
Content-Type: application/json

{
 "requestId": "RST-260602-5A71",
 "otp": "000137"
}

Attempt sample: 001 of 120 controlled invalid submissions

RESPONSE

HTTP/2 400 Bad Request
Content-Type: application/json
X-Request-ID: idp-260602-93ac

{
 "error": "invalid_otp",
 "message": "Verification code is invalid.",
 "remainingAttempts": null,
 "locked": false
}
No Retry-After header observed.

Validation result:

The endpoint continued accepting invalid OTP guesses without logout or backoff after repeated failures.

Evidence CLT-AL-04: masked request/response proof and validation result

Affected component POST /api/v2/auth/password-reset/verify	Preconditions Valid password reset requestId generated for a known learner or instructor account.
Detailed proof-of-concept steps - Generated a password reset flow for a QA learner account and captured the OTP verification request. - Submitted 120 invalid OTP values in a controlled assessment window using the same requestId. - The endpoint returned identical invalid_otp responses and did not lock the request, delay responses or return a Retry-After header.	Business impact A six-digit reset OTP can be guessed more effectively within its validity period if attempts are not limited. This increases account takeover likelihood for known email addresses.
Likely root cause Failed OTP attempts are not counted and enforced per requestId, user account, IP address or device context.	Recommended remediation Limit OTP attempts per requestId and user, expire reset requests after a small number of failures, add progressive delay, return Retry-After where appropriate, and alert on abnormal reset verification patterns.

05		CLT-AL-05 - Assignment submission files are downloadable through predictable file keys		
		Severity: Medium CVSS: 6.5 Owner: Application Engineering		
Severity	CVSS v3.1	Priority	Status	OWASP mapping
Medium	6.5	P2	Open	OWASP Top 10: A01 Broken Access Control / OWASP WSTG Authorization Testing

NorthQuill Evidence Console - Repeater - CLT-AL-05

ProxyRepeaterComparerLoggerNotes

Assignment submission files are downloadable through predictable file keys

Evidence captured in authorized UAT scope. Session tokens, user identifiers and personal data are masked.

REQUEST

```
GET
/api/v2/submissions/files/FILE-DBMS-2606-008742/download
HTTP/2
Host: uat.asterlearn.example
Authorization: Bearer eyJ...student.greenfield
Accept: application/json

Owned key observed: FILE-DBMS-2606-008739
Test key requested: FILE-DBMS-2606-008742
```

RESPONSE

```
HTTP/2 200 OK
Content-Type: application/json

{
  "fileKey": "FILE-DBMS-2606-008742",
  "ownerStudentId": "STU-GFI-10588",
  "fileName": "normalization-lab-report.pdf",
  "downloadUrl": "https://files.asterlearn.example/signed/eyJ...",
  "expiresIn": 600
}
```

Validation result: A student token obtained a signed URL for a fileKey associated with a different student submission.

Evidence CLT-AL-05: masked request/response proof and validation result

Affected component GET /api/v2/submissions/files/{fileKey}/download	Preconditions Authenticated student with access to their own assignment submissions.
Detailed proof-of-concept steps - Downloaded an owned assignment file and observed the fileKey format in the API call. - Changed the numeric suffix to a nearby value that was not owned by the same account. - The API returned another student submission file metadata and a signed download URL.	Business impact Students may access other learners assignment submissions, leading to academic integrity issues, privacy exposure and unauthorized disclosure of original work.
Likely root cause The download endpoint validates authentication but not ownership of the submission file before generating the signed URL.	Recommended remediation Use non-sequential identifiers, enforce ownership and course enrollment checks before URL generation, bind signed URLs to the authorized user/session where possible, and log denied cross-owner attempts.

06		CLT-AL-06 - Credentialed CORS policy reflects untrusted origins		
Severity		CVSS v3.1	Priority	Status
Medium		6.2	P2	Open
		OWASP mapping		
		OWASP Top 10: A05 Security Misconfiguration / OWASP API8 Security Misconfiguration		

NorthQuill Evidence Console - Repeater - CLT-AL-06

ProxyRepeaterComparerLoggerNotes

Credentialed CORS policy reflects untrusted origins

Evidence captured in authorized UAT scope. Session tokens, user identifiers and personal data are masked.

REQUEST

OPTIONS /api/v2/analytics/course/CSE-SEM4-DBMS HTTP/2
Host: uat.asterlearn.example
Origin: https://audit-lab.external.example
Access-Control-Request-Method: GET
Access-Control-Request-Headers: authorization,content-type

RESPONSE

HTTP/2 204 No Content
Access-Control-Allow-Origin: https://audit-lab.external.example
Access-Control-Allow-Credentials: true
Access-Control-Allow-Methods: GET,POST,PUT,DELETE,OPTIONS
Vary: Origin

Follow-up GET returned course analytics metadata.

Validation result:

The UAT API trusted an origin outside the approved application origin set and allowed credentialed browser requests.

Evidence CLT-AL-06: masked request/response proof and validation result

Affected component /api/v2/analytics/* and /api/v2/students/*	Preconditions Authenticated browser session and request initiated from an external origin.
Detailed proof-of-concept steps - Sent a preflight request with Origin set to an audit-controlled external origin. - The API reflected the supplied Origin and returned Access-Control-Allow-Credentials: true. - A follow-up credentialed request to the analytics endpoint returned course analytics metadata.	Business impact A malicious webpage visited by an authenticated user may be able to read API responses if browser credentials are attached and the application trusts arbitrary origins.
Likely root cause CORS middleware reflects Origin dynamically and permits credentials instead of enforcing a strict allow-list of approved application origins.	Recommended remediation Replace reflective CORS with an explicit allow-list, disallow credentials for untrusted origins, validate CORS behavior in automated tests, and separate public resources from authenticated APIs.

07		CLT-AL-07 - Grade export is vulnerable to spreadsheet formula injection		
Severity		CVSS v3.1	Priority	Status
Medium		5.9	P3	Open
		OWASP mapping		
		OWASP Top 10: A03 Injection / OWASP WSTG Input Validation Testing		

NorthQuill Evidence Console - Repeater - CLT-AL-07

ProxyRepeaterComparerLoggerNotes

Grade export is vulnerable to spreadsheet formula injection

Evidence captured in authorized UAT scope. Session tokens, user identifiers and personal data are masked.

REQUEST

```
POST /api/v2/gradebook/comments HTTP/2
Host: uat.asterlearn.example
Authorization: Bearer eyJ...teaching_assistant
Content-Type: application/json

{
  "studentId": "STU-GFI-10431",
  "assessmentId": "ASM-DBMS-MIDTERM",
  "comment": "=HYPERLINK(\"https://audit-lab.example/AL2606\", \"review\")"
}
```

RESPONSE

```
HTTP/2 200 OK
Content-Type: text/csv
Content-Disposition: attachment;
filename="gradebook-CSE-SEM4.csv"

student_id,assessment,score,comment
STU-GFI-10431,ASM-DBMS-MIDTERM,83,"=HYPERLINK(\"https://audit-lab.example/AL2606\", \"review\")"
```

Validation result:

The exported CSV included the unescaped formula-leading grade comment exactly as submitted.

Evidence CLT-AL-07: masked request/response proof and validation result

Affected component POST /api/v2/gradebook/comments and GET /api/v2/gradebook/export.csv	Preconditions Instructor or teaching assistant can add gradebook comments that are later exported by an administrator.
Detailed proof-of-concept steps - Submitted a gradebook comment beginning with a spreadsheet formula control character using a controlled audit marker. - Exported the gradebook CSV from the administrator workflow. - The CSV preserved the formula-like value without neutralization, which spreadsheet clients may interpret when opened.	Business impact Opening exported CSV files in spreadsheet software may trigger formula evaluation, potentially causing data exfiltration prompts, command-like behaviors in legacy clients or manipulation of exported grade data.
Likely root cause User-supplied export fields are written directly to CSV without formula neutralization for values beginning with =, +, -, @ or tab-prefixed expressions.	Recommended remediation Neutralize formula-leading characters in CSV exports by prefixing a single quote or tab-safe encoding, document export handling, and add tests for fields beginning with spreadsheet formula characters.

08		CLT-AL-08 - Missing security headers and weak SameSite cookie setting reduce browser-side protections		
		Severity: Medium CVSS: 5.4 Owner: DevOps + Platform Engineering		
Severity	CVSS v3.1	Priority	Status	OWASP mapping
Medium	5.4	P3	Open	OWASP Top 10: A05 Security Misconfiguration / OWASP WSTG Configuration Testing

NorthQuill Evidence Console - Repeater - CLT-AL-08

ProxyRepeaterComparerLoggerNotes

Missing security headers and weak SameSite cookie setting reduce browser-side protections

Evidence captured in authorized UAT scope. Session tokens, user identifiers and personal data are masked.

REQUEST

```
GET /dashboard HTTP/2
Host: uat.asterlearn.example
Cookie: al_session=5f4c...masked
Accept: text/html
User-Agent: AuditBrowser/1.0
```

RESPONSE

```
HTTP/2 200 OK
Content-Type: text/html; charset=utf-8
Set-Cookie: al_session=5f4c...; Path=/; Secure; HttpOnly

Missing headers observed:
- Content-Security-Policy
- X-Frame-Options / frame-ancestors
- Referrer-Policy
- X-Content-Type-Options
- Strict-Transport-Security
```

Validation result: Responses lacked browser hardening headers and the session cookie did not include a SameSite attribute.

Evidence CLT-AL-08: masked request/response proof and validation result

Affected component Primary web responses including /login, /dashboard, /courses and /gradebook	Preconditions Browser access to application pages.
Detailed proof-of-concept steps - Captured response headers from unauthenticated and authenticated web pages. - Confirmed missing Content-Security-Policy, frame-ancestors or X-Frame-Options, Referrer-Policy and X-Content-Type-Options headers. - Observed the primary session cookie set with Secure and HttpOnly but without a SameSite attribute.	Business impact The platform has reduced resilience against clickjacking, script injection impact, MIME sniffing, referrer leakage and cross-site request contexts. Missing SameSite also weakens default browser CSRF protections.
Likely root cause Security headers are not centrally enforced at the edge gateway and session cookie policy is not fully hardened in the identity middleware.	Recommended remediation Apply a baseline header policy at the gateway, including CSP with frame-ancestors, HSTS, X-Content-Type-Options, Referrer-Policy and Permissions-Policy. Set SameSite=Lax or Strict for session cookies unless a documented exception exists.

The remediation plan should be tracked as a release-gate activity. Closure should be based on reproducible retest evidence against the original proof paths rather than ticket status alone.

Workstream	Recommended actions	Primary owner	Target
Authorization	Centralize institution/tenant resolution, enforce object ownership for profiles and submissions, block client-controlled role assignment and add negative authorization tests.	Backend Engineering + QA	P1 sprint
Stored content	Sanitize announcement rich text, encode output by context, remove unsafe attributes and deploy CSP after compatibility validation.	Frontend + Backend	P1 sprint
Identity recovery	Throttle OTP attempts, lock reset request after failures, add progressive delay and monitor abuse signals.	Identity Engineering	P2 sprint
Gateway configuration	Restrict CORS, deploy browser security headers, harden SameSite cookie policy and normalize response headers centrally.	Platform + DevOps	P2 sprint
Export and file handling	Neutralize CSV formula-leading characters, verify file ownership before signed URL generation and audit export/download activity.	Application Engineering	P2/P3 sprint

Retest criteria

Closure evidence expected	Retest method
- Patched build version and deployment timestamp - Negative authorization evidence for cross-institution and role-assignment tests - Sanitization proof for stored announcement content - Header/CORS/cookie captures from the deployed gateway - CSV/file-download regression test references	- Replay original PoC requests with the same roles and verify expected denial or sanitized output - Confirm no regression across adjacent roles, courses and institution boundaries - Validate operational logs capture denied attempts without leaking sensitive data - Update status as Closed, Partially Closed or Risk Accepted with evidence

Closure statement

Assessor statement	The observations were reproducible during the authorized assessment window and are presented with masked evidence for remediation use.
Client action required	Assign remediation owners, track fixes by priority, provide patched build details and schedule retesting for all open findings.
Distribution control	This document contains confidential security information and should be shared only with governance, engineering and remediation stakeholders.